

Web Application Security Assessment Report

Name: Sulyman Ridwan Oladimeji

Task 1: Web Application Security Testing

Program: Future intern Cybersecurity Analyst

Tools Used: Kali linux, OWAPSP, ZAP,Burp suite, SQL Map

Date: July 17 2025



Excursive Summary

This assessment focused on testing the security of OWASP juice shop using OWASP ZAP. The primary goal was to identify common vulnerabilities listed in the OWASP Top 10, including Cross-site Scripting (XSS), SQL injection (SQLi), and security misconfigurations. OWASP ZAP was used to perform automated scanning of the application. Key vulnerabilities were identified, and remediation strategies are provided to mitigate each risk.

Methodology

- ❖ The OWASP juice shop web app was set up locally using Node.js and accessed via <http://localhost:3000>.
- ❖ OWASP ZAP was launched and configured to perform an automated scan of the application.
- ❖ The scanner performed spidering and active testing to discover input forms, user actions, and vulnerabilities.
- ❖ Detected issues were analyzed and mapped to their respective OWASP Top 10 categories.
- ❖ Each vulnerability was documented with risk level, affected URL, description, screenshot, and remediation advice.

Vulnerability Findings Summary

Vulnerability Type	Affected URL	Severity	OWASP top 10 category
SQL Injection	/rest/products/search?= =' OR `1`='1	High	A03 - Injection
Missing Anti-CSRF Tokens	/profile	Medium	A01- Broken Access Control
Cross-Domain Misconfiguration	/	Medium	A05 - Security Misconfiguration
Private IP Disclosure	/rest/track-order	Low	A06 - Vulnerable and Outdated Components
Cloud Metadata Potentially Exposed	/.well-known/aws/metadata	High	A05 - Security Misconfiguration

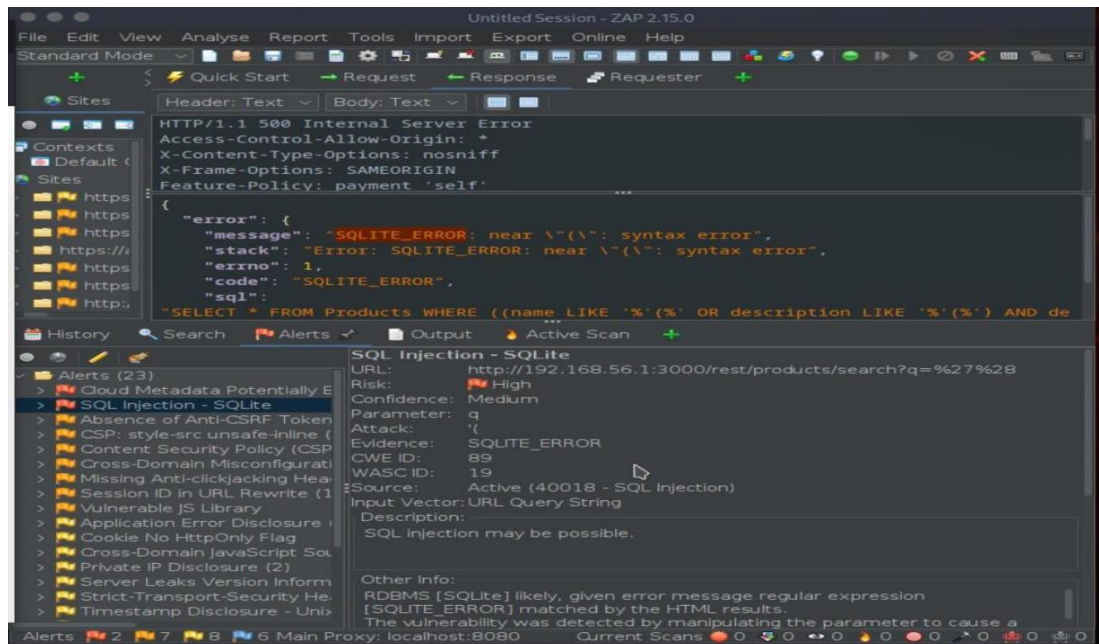
Detailed Findings & Recommendations

1. SQL INJECTION

- ✧ Affected URL: /rest/products/search?=
=' OR `1`='1
- ✧ Risk Level: High
- ✧ OWASP Category: A03 - Injection
- ✧ Impact: Attackers may manipulate backend SQL queries to access or alter data.

Remediation:

- ✧ Use parameterized queries or ORM frameworks.
- ✧ Avoid dynamic SQL concatenation.
- ✧ Validate and sanitize user inputs.

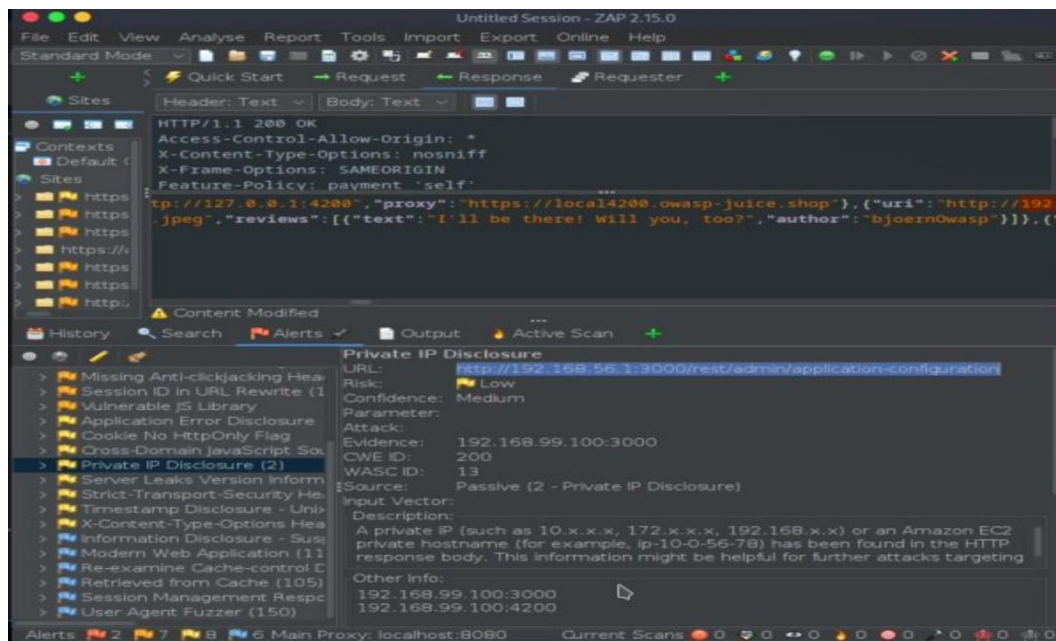


2. Cross-Domain Misconfiguration

- ✧ Affected URL: /
- ✧ Risk Level: Medium
- ✧ OWASP Category: A05 - Security Misconfiguration
- ✧ Impact: Permits requests from unauthorized domains, enabling cross-origin attacks.

Remediation:

- ✧ Restrict Access-Control-Allow-Origin to trusted domains.
- ✧ Do not use wildcard (*) unless required and safe



OWASP Top 10 Mapping

OWASP Category	Covered in Test?
A01 - Broken Access Control	✓
A02 - Cryptographic Failures	X
A03 - Injection (XSS)	✓
A04 - Insecure Design	X
A05 - Security Misconfiguration	✓
A06 - Vulnerable and Outdated Components	✓
A07 - Identification and Authentication Failures	✓
A08 - Software/Data integrity Failures	X
A09 - Logging and Monitoring Failures	X
A10 - SSRF (Server-side Request Forgery)	X

Conclusion

The scan revealed significant vulnerabilities such as SQL Injection, missing CSRF protections, and potential cloud metadata exposure. These issues, if exploited, can lead to data leakage, unauthorized access, and compromise of internal systems. Immediate attention to remediation steps is recommended to enhance the web application's security posture.